QAYRAWAN INFORMATION SYSTEMS

Cybersecurity Incident Response Plan

ECC Compliance Program · Operate phase

Document ID	QIS-IRP-001
Version	0.2 (Draft)
Date	9 November 2026
Classification	Internal
Prepared by	Naif Alsalem, GRC Lead

Language. This document is issued in Arabic and English. In case of conflict, the Arabic text prevails.

Fictional case study. Qayrawan Information Systems (QIS), its people and its clients are invented for a professional portfolio. Any resemblance to a real organization is unintended. The regulators and frameworks named are real.

Document control

Role	Job title	Name	Status
Owner	GRC Lead (interim owner until a Head of Cybersecurity is appointed)	Naif Alsalem	Complete
Reviewer	Chief Technology Officer	Reem Al-Otaibi	Pending
Endorsed by	Cybersecurity Steering Committee	—	Pending
Approver	Chief Executive Officer	Faisal Al-Harbi	Pending

Version history

Version	Date	Author	Change
0.1	7 Nov 2026	Naif Alsalem	First draft for review, translated from the Arabic lead text
0.2	9 Nov 2026	Naif Alsalem	NCA deadline source updated; PDPL draft amendments applied (notice for every breach)

Review cycle: At least annually, after every critical or high-severity incident, and after any major change to technology, services or regulatory requirements.

Distribution: the CEO, incident response team members, the Steering Committee and the Personal Data Protection Officer. Not shared outside QIS without the GRC Lead's approval, except a summary copy for clients where a contract requires it.

1. Purpose and scope

1.1 Purpose

This plan sets how Qayrawan Information Systems detects, classifies, contains, eradicates, recovers from and reports cybersecurity incidents, and how it meets its duties to government clients and regulators. It treats risk R-16 in the risk register.

1.2 Scope

The plan covers all QIS systems, networks and data; the systems QIS hosts, builds or manages for Clients A to F; access to client networks through the remote management tool; and the services provided by the cloud provider. It applies to all staff, contractors and third parties working for QIS.

1.3 Out of scope

- Incidents inside client systems that QIS does not manage, unless the client asks for support under the contract.
- Physical security incidents with no cyber element.
- Routine support requests with no security impact.

2. Regulatory and contractual framework

QIS is a service provider to government entities. It must respond to incidents under its client contracts, and it supports clients in meeting their own duties to regulators.

Party	Framework	Why it applies	Main obligation
Government clients	Service contracts and data processing terms	QIS runs their systems and processes their data	Notify the client within contractual deadlines; support investigation and recovery
National Cybersecurity Authority	Essential Cybersecurity Controls (ECC-2:2024), subdomain 2-13	Clients apply the controls to their service providers	A documented response plan, incident classification, and reporting through the Haseen platform where required
National Cybersecurity Authority	Cloud Cybersecurity Controls (CCC)	QIS hosts government systems in the cloud	Coordinate response with the cloud provider under shared responsibility
SDAIA	Personal Data Protection Law and its implementing regulation	QIS processes personal data for clients	Notify the controller immediately of every breach so it can notify SDAIA within 72 hours

3. Definitions

Term	Definition
Cybersecurity incident	Any event that actually or potentially threatens the confidentiality, integrity or availability of QIS's or its clients' systems or data.
Major incident	An incident rated critical or high under section 5, requiring client notification.
Personal data breach	Unauthorized access to, disclosure, alteration, loss or destruction of personal data.
Incident response team (CSIRT)	The team that carries out the technical response and coordination during an incident.
Indicator of compromise (IOC)	Technical evidence of a compromise, such as an address, file or suspicious activity.
RTO / RPO	Recovery time objective / recovery point objective, as set in the Business Continuity Plan.

4. Roles and responsibilities

Role	Held by	Responsibility during an incident
Incident lead	GRC Lead (interim)	Owns incident management, approves the severity rating, and is the contact point for clients and regulators.

Role	Held by	Responsibility during an incident
Technical lead	Senior cybersecurity engineer	Coordinates technical containment, eradication and recovery.
Technical team	Security engineer, IT operations, hosting, development, and the managed SOC	Detection, investigation and technical remediation.
Personal Data Protection Officer	GRC Lead	Assesses the effect on personal data and notifies the controller.
Client coordinator	Head of Service Delivery	Day-to-day contact with client technical teams; carries out containment steps in managed services.
Legal and contracts	Chief Financial Officer	Reviews contractual obligations, liaises with legal parties, and handles incidents involving staff or contractors.
Crisis management team	CEO, CTO and CFO	Business and resource decisions in critical incidents; approves external messages.

The cloud provider and the managed SOC must notify QIS of any incident affecting its services or data within 4 hours for critical incidents, as their contracts require. The incident lead keeps a list of security contacts at third parties and their contractual notification deadlines.

5. Incident severity

Level	Definition	QIS example	Response starts	Escalation
Critical	Confirmed compromise affecting several clients or large amounts of personal data, or a critical service outage	Ransomware spreading through the remote tool into client networks, or citizen data exposed from the portal	Immediately (within 1 hour)	CEO and crisis team; full team activated
High	Incident with tangible impact on one client, or risk of escalation	A technician account with client network access is compromised	Within 4 hours	Incident lead and CTO
Medium	Contained incident with limited impact inside QIS	Malware isolated on one laptop	Within 24 hours	Technical lead
Low	Minor or informational event	A blocked phishing attempt, or an acceptable-use breach	Normal working hours	Log only

6. Response lifecycle

#	Stage	Main activities
1	Preparation	Keep the team and contact lists current, detection tools ready, playbooks for each incident type, and yearly training.
2	Detection and analysis	Triage alerts, confirm scope, set severity, and open the incident record and timeline.
3	Containment	Isolate affected systems or accounts, cut the remote tool's access to clients if needed, and revoke compromised credentials, preserving evidence before any step that would destroy it.
4	Eradication	Remove the root cause and fix the exploited weakness, not just the symptom.
5	Recovery	Restore from clean, verified backups, watch for reinfection, and confirm normal operation with the system owner and client.
6	Post-incident	Root cause analysis, a lessons-learned report, and follow-up of improvement actions until they close.

Closure criteria

- Affected systems are confirmed clean and monitored for a period matching the incident's severity.
- The root cause or exploited weakness is fixed.
- The system owner, and the client where affected, agree normal operation has resumed.
- All notifications required in section 8 are complete, or any still pending are recorded.
- The incident report form (Appendix B) is complete.
- The incident lead records the closure, its date and its justification.

7. Detection and internal escalation

Detection sources: managed SOC alerts, endpoint detection and response tools, client reports, third-party reports, and staff reports to security@qis.example or extension 2100.

Time from detection	Action	Responsible
Within 15 minutes	Log the incident, triage, and set an initial severity	On-call security engineer or the SOC
Within 30 minutes	Confirm severity; notify the incident lead for medium incidents and above	Technical lead
Within 1 hour	Activate the full team and notify the CEO for critical incidents	Incident lead
Per section 8	Notify clients and regulators	Incident lead and Data Protection Officer

8. External notification

Party	When	Deadline	Channel	Content
Affected client	Any incident affecting its systems, data or services	4 hours for critical and high incidents; 24 hours at most for others	Security contact named in the contract	Incident summary, affected systems and data, containment steps, and the time of the next update
National Cybersecurity Authority	Where the client or the Authority requires QIS to report directly	As instructed by the Authority and the client, within 24 hours at most	The Haseen platform	Technical details, indicators of compromise, impact assessment and remediation
Controller (client), for the Personal Data Protection Law	A breach of personal data processed for the client	Immediately, and within 24 hours of discovery at most	The client's data protection officer	Nature of the breach, data categories and approximate number of people, likely consequences, and actions taken
Cloud provider	An incident affecting hosted systems or needing its support	Immediately	The provider's security support channel	Only what is needed for containment and investigation

One incident may require several notifications at once, so the incident lead assigns who prepares each one from the start, so deadlines do not compete for the same people.

8.1 Regulatory deadline verification log

Party	Deadline above	Source	Verification status
National Cybersecurity Authority	24 hours at most	Duty to report from ECC-2:2024 subdomain 2-13; time limit as confirmed by a GRC practitioner	To be matched against the official ECC text before approval
SDAIA	72 hours for the controller to notify SDAIA, for every breach whatever its impact	Implementing regulation of the Personal Data Protection Law, and its draft amendments (October 2026)	The current regulation limits notice to breaches that may cause harm; the draft amendments extend it to every breach. QIS applies the stricter rule now
Clients	4 hours / 24 hours	Service contracts and data processing terms	To be verified for each contract

9. Communication plan

Audience	When	Responsible	Channel	Requirements
Response team	On confirmation and at every major change	Incident lead	A dedicated secure channel for the incident	Incident number and severity, confirmed facts, decisions, and the time of the next update
Senior management	Critical and high incidents, and when impact changes	Incident lead	Meeting or secure call, plus a short report	Business and client impact, recovery status, and decisions needed
Affected clients	Per section 8, then regularly until closure	Incident lead and client coordinator	Contractual security contact	One consistent message with confirmed facts only
Regulators	Where required under section 8	Incident lead	Official channels	A single point of contact; record every submission and acknowledgment
Staff	When they need to act	Incident lead	Internal email	The instructions needed, without sensitive details
Media	QIS speaks to the media only in coordination with the affected client	CEO	Approved statement	No speculation, and no disclosure of incident details or the client's identity

10. Evidence and forensics

- Logs, memory and disk images, and cloud system logs are preserved before any remediation step that could destroy them, where that is possible and safe.
- Each piece of evidence has a documented chain of custody: its source, who collected it, when, every transfer, and a hash value to verify integrity.
- Evidence is kept in a secure repository with restricted access.
- Security event logs are kept for at least 12 months, or longer where a contract or law requires.
- An external forensics firm is brought in for critical incidents, or when a client or the authorities request it.

11. Link with the Business Continuity Plan

If an incident stops a service, the Business Continuity Plan (QIS-BCP-001) is activated alongside this plan. The response team owns the security track (containment, eradication and investigation), the continuity team owns service restoration, and the crisis management team coordinates both so they do not work in isolation.

12. Post-incident review

Step	Timing	Responsible
Lessons-learned session	Within 5 working days of closure	Incident lead
Root cause report	After the session, submitted to the Steering Committee	Incident lead
Corrective action follow-up	Until closed; new risks are recorded in QIS-RR-001	Action owners
Update the plan where gaps appeared	As needed	Plan owner

13. Testing, training and maintenance

Activity	Frequency	Details
Tabletop exercise	At least annually	A scenario from Appendix C, with the client coordinator taking part and at least one client invited
Training	Annually for all staff	With extra specialist training for response team members
Plan review	Annually	And after every critical incident or major regulatory change

14. Metrics and reporting

Metric	Definition	Reported to	Frequency
Mean time to detect (MTTD)	From occurrence to detection	Steering Committee	Quarterly
Mean time to contain (MTTC)	From detection to containment	Steering Committee	Quarterly
Incidents by severity	Number of incidents at each level	Steering Committee	Quarterly
Client notification compliance	Share of notifications sent within the deadline	Steering Committee	Quarterly
Corrective action closure	Share of actions closed on time	Steering Committee	Quarterly

Appendix A. Response team list

Role	Name	Extension	Deputy
Incident lead	Naif Alsalem	2101	Reem Al-Otaibi

Role	Name	Extension	Deputy
Technical lead	Senior cybersecurity engineer	2102	Cybersecurity engineer
Client coordinator	Sultan Al-Dossary	2201	Managed services supervisor
Legal and contracts	Majed Al-Qahtani	2301	HR manager
Crisis management team	Faisal Al-Harbi	2001	Reem Al-Otaibi
Managed SOC	Set when contracted (R-03)	—	—

Mobile numbers and client contacts are kept in an updated copy of this appendix held by the incident lead, and are not published.

Appendix B. Incident report form

Field	Content
Incident number, detection date and time	
Detection source and reporter	
Severity and justification	
Affected systems, clients and data	
Timeline of events and actions	
Containment, eradication and recovery steps	
External notifications: party, time, reference	
Root cause	
Lessons learned and corrective actions	
Closure: date and approver	

Appendix C. Short playbooks

C-1 Ransomware spreading through the remote management tool (critical)

- Shut down the remote management tool and all VPN connections to clients immediately, on the incident lead's decision.
- Isolate infected devices from the network without powering them off, and capture memory images.
- Notify every connected client within 4 hours, even if no infection is confirmed there.
- Identify the ransomware strain and entry point, and revoke all administrative credentials.

- Restore from immutable backups after verifying they are clean, and activate the Business Continuity Plan.
- Do not pay any ransom or contact the attackers except by decision of the crisis management team, in coordination with the competent authorities.

C-2 Compromised technician account with client network access (high)

- Disable the account and revoke its sessions and access keys immediately.
- Review remote tool and VPN logs to establish what was done at each client.
- Notify the affected client within 4 hours and share the suspicious activity so it can check its environment.
- Establish how the account was compromised (phishing, reused password or an infected device) and fix it.

C-3 Citizen data exposed from the portal (critical)

- Shut down or restrict the exploited API, by joint decision with Client A.
- Preserve portal, web application firewall and database logs.
- Identify the exposed records and the number of people affected, and notify Client A as controller immediately, within 24 hours at most.
- Fix and test the weakness before restarting, and carry out a data protection impact assessment.